

Writeup - [Holmes 2025]

Informations générales

- **Nom du CTF** : [Holmes 2025]
 - **Type d'événement** : [Public]
 - **Format**: [Jeopardy]
 - **Lieu** : [En ligne]
 - **Nombre de joueurs** : [11007]
 - **Nombre d'équipes** : [6907]
 - **Nombre de challenges** : [5 : 1/Catégorie]
 - **Catégorie** : [threat Intelligence / SOC / DFIR / Malware Reversing]
 - **Difficulté** : [Easy / Medium / Hard]
 - **Nombre de points maximum** : [9000 pts]
 - **Auteur du challenge** : [Hack The Box]
-

Contexte

Il s'agit de mon premier ctf, donc j'étais plus là pour découvrir que pour trouver des flags. J'ai cependant réussi à en trouver un flag sur un challenge easy. Pour le reste j'ai essentiellement "visité" les challenge en essayant de voir si je pouvais avoir des idées.

Présentation du ctf

Enoncé

Holmes left some vague context (as he does) before heading out into the field. Here's what we know:

We are getting strange readings from around the city; there were some targeted attacks on local businesses that seemed off. Who was chosen and the type of attack piqued Holmes' interest, so he set out ahead of us.

Odd though... he was muttering about something that had happened a while back, and he expressed distress about a personal AI he developed named WATSON.

See, WATSON was his collaborative ally in his attempts to curb the crime happening around the city. However, some time ago, a catastrophic false-alert event caused by WATSON triggered a year-long manhunt for a breach that never existed. We were chasing ghosts.

Reputations ruined. Careers ended. The entire city was paralyzed over a phantom that was in our own backyard. The event known as NULLINC caused Holmes to shut down his creation, his friend.

So, we are just as confused about why he'd mention WATSON now, but you never can get a read on that man.

Head out into the field and assist him in finding out what's going on. We are counting on your detectives.

Liste des challenges

- **The Card** : Easy
 - Holmes receives a breadcrumb from Dr. Nicole Vale - fragments from a string of cyber incidents across Cogwork-1. Each lead ends the same way: a digital calling card signed JM.
- **The Enduring Echo** : Easy
 - LeStrade passes a disk image artifacts to Watson. It's one of the identified breach points, now showing abnormal CPU activity and anomalies in process logs.
- **The Watchman's Residue** : Medium
 - With help from D.I. Lestrade, Holmes acquires logs from a compromised MSP connected to the city's financial core. The MSP's AI servicedesk bot looks to have been manipulated into leaking remote access keys - an old trick of Moriarty's.
- **The Tunnel Without Walls** : Hard
 - A memory dump from a connected Linux machine reveals covert network connections, fake services, and unusual redirects. Holmes investigates further to uncover how the attacker is manipulating the entire network!
- **The Payload** : Hard
 - With the malware extracted, Holmes inspects its logic. The strain spreads silently across the entire network. Its goal? Not destruction-but something more persistent...friends. NOTE: The downloaded file is active malware. Take the necessary precautions when attempting this challenge.

Challenge - [The Enduring Echo]

Présentation du challenge

Ce challenge nous place dans la peau d'un analyste soc. Nous devons explorer les logs d'un système windows pour trouver les 14 flags.

1. What was the first (non cd) command executed by the attacker on the host? (string)
2. Which parent process (full path) spawned the attacker's commands?
(C:\FOLDER\PATH\FILE.ext)
3. Which remote-execution tool was most likely used for the attack? (filename.ext)

4. What was the attacker's IP address? (IPv4 address)
5. What is the first element in the attacker's sequence of persistence mechanisms? (string)
6. Identify the script executed by the persistence mechanism. (C:\FOLDER\PATH\FILE.ext)
7. What local account did the attacker create? (string)
8. What domain name did the attacker use for credential exfiltration? (domain)
9. What password did the attacker's script generate for the newly created user? (string)
10. What was the IP address of the internal system the attacker pivoted to? (IPv4 address)
11. Which TCP port on the victim was forwarded to enable the pivot? (port 0-65565)
12. What is the full registry path that stores persistent IPv4 → IPv4 TCP listener-to-target mappings? (HKLM.....)
13. What is the MITRE ATT&CK ID associated with the previous technique used by the attacker to pivot to the internal system? (Txxxx.xxx)
14. Before the attack, the administrator configured Windows to capture command line details in the event logs. What command did they run to achieve this? (command)

Analyse initiale

- On nous fourni une copie d'un système windows.
 - La racine de ce système contient 3 fichier (**2025-08-25T20_20_59_5246365_ConsoleLog.txt**, **2025-08-25T20_20_59_5246365_CopyLog.csv**, **2025-08-25T20_20_59_5246365_SkipLog.csv.csv** et un dossier '**C**').
 - Le dossier C contient une arborescence complète de système windows avec 3 users **Administrator**, **Default** et **Werni**.
-

Flags résolus

Question :

Which parent process (full path) spawned the attacker's commands?
(C:\FOLDER\PATH\FILE.ext)

Flag :

C:\Windows\System32\wbem\WmiPrvSE.exe

La démarche :

Ce que l'on savait à ce stade :

1. L'attaquant à lancé un cmd
2. Il l'a utilisé pour créer une tâche planifiée SysHelper Update.
(C:\Windows\System32\Tasks\SysHelper Update)
3. Cette tâche appelle un script powershell JM.ps1 qui crée un user avec mot de passe (entre autre).

Comment répondre à la question :

Exploration de fichiers de logs. Je n'avais jamais fais donc je me suis lancé sur linux et avec un peu d'obstination j'ai trouvé ce dont j'avais besoin.

- Il y'a un fichier de log security.evtx qui semble prometteur

(The_Enduring_Echo/C/Windows/System32/winevt/logs/Security.evtx)

- J'ai donc essayé de l'ouvrir mais sur linux c'est une tannée (edit : depuis que j'ai fais le module htb academy sur les logs Windows je sais comment trouver l'info en 5 minutes, et pourquoi ça ne servait à rien de s'obstiner sur Linux alors que Windows fournit tous les outils)

- J'ai donc fait un script qui parse le fichier et m'affiche ce dont j'ai besoin :

```
# === Fichier à parser ===
$evtxPath = ".\Security.evtx" # ou
".\The_Enduring_Echo\C\Windows\System32\winevt\Logs\Security.evtx"

# === Lecture des events : on lit tout puis on filtre par Id ===
Write-Host "Lecture des events depuis $evtxPath ..."
$allEvents = Get-WinEvent -Path $evtxPath -ErrorAction Stop

# Filtrer uniquement les events 4688 (création de processus)
$events = $allEvents | Where-Object { $_.Id -eq 4688 }
if (-not $events -or $events.Count -eq 0) {
    Write-Warning "Aucun événement 4688 trouvé dans $evtxPath"
    return
}

# === Fonction utilitaire pour parser EventData en dictionnaire ==
function Parse-4688Event($evt) {
    if (-not $evt) { return $null }
    $xml = [xml]$evt.ToXml()
    $data = @{}
    foreach($d in $xml.Event.EventData.Data){
        $name = $d.Name
        if (-not $name) { $name = ("Field" +
            ([System.Guid]::NewGuid().ToString().Substring(0,8))) }
        $data[$name] = $d.'#text'
    }
    $data['TimeCreated'] = $evt.TimeCreated
    return [PSCustomObject]$data
}

# === Parse en mémoire ===
$parsed = $events | ForEach-Object { Parse-4688Event $_ } | Where-Object {
    $_ -ne $null }

# Affiche les 5 derniers événements 4688 (pour vérifier qu'il parse bien
quelque chose)
Write-Host "`n5 derniers events 4688 (TimeCreated, NewProcessName,
```

```

CommandLine, SubjectUserName) :"$
$parsed | Sort-Object TimeCreated -Descending | Select-Object -First 5
TimeCreated, NewProcessName, CommandLine, SubjectUserName | Format-Table -
AutoSize

# === Recherche initiale : JM.ps1 (le nom du script powershell) dans
CommandLine/NewProcessName ===
$candidates = $parsed | Where-Object {
    ($_.CommandLine -and $_.CommandLine -match 'JM\.ps1') -or
    ($_.NewProcessName -and $_.NewProcessName -match 'JM\.ps1')
}

# Fallback : chercher powershell.exe lancé par Werni
if (-not $candidates -or $candidates.Count -eq 0) {
    Write-Host "`nAucun event mentionnant JM.ps1 trouvé. Recherche
powershell.exe lancé par 'Werni'..."
    $candidates = $parsed | Where-Object {
        ($_.NewProcessName -and $_.NewProcessName -match 'powershell.exe')
    }
}
if (-not $candidates -or $candidates.Count -eq 0) {
    Write-Warning "Aucun candidat automatique trouvé (ni JM.ps1 ni
powershell.exe par Werni)."
    Write-Host "`nAffichage des 30 derniers events 4688 pour inspection
manuelle :"$
    $parsed | Sort-Object TimeCreated -Descending | Select-Object -First
30 TimeCreated, NewProcessName, CommandLine, SubjectUserName | Format-
Table -AutoSize
    return
}

# === Corrélation parent -> enfant ===
$results = foreach($c in $candidates | Sort-Object TimeCreated) {
    $foundParent = $null
    $parentInfo = $null
    if ($c.ParentProcessName) {
        $foundParent = $c.ParentProcessName
        $parentInfo = "ParentProcessName field"
    }
    elseif ($c.ParentProcessId) {
        $parentId = $c.ParentProcessId

        # Cherche un event dont NewProcessId correspond
        $parentEvent = $parsed | Where-Object {
            $_.NewProcessId -and (
                ($_.NewProcessId -eq $parentId) -or
                ($_.NewProcessId -eq ('0x' + $parentId.TrimStart('0x')))) -
or

```

```

        (try { [int64]$_ .NewProcessId -eq [int64]$parentId } catch
{ $false })
    )
} | Select-Object -First 1
if ($parentEvent) {
    $foundParent = $parentEvent.NewProcessName
    $parentInfo = "Résolu via ParentProcessId -> NewProcessId"
} else {
    $foundParent = "Parent non résolu (ParentProcessId=$parentId)"
}
}
[PSCustomObject]@{
    TimeCreated = $c.TimeCreated
    ChildNewProcessName = $c.NewProcessName
    ChildCommandLine = $c.CommandLine
    ParentResolved = $foundParent
    ParentResolutionMethod = $parentInfo
}
}

# === Affiche résultats et formate FLAG si chemin absolu ===
$results | Format-Table -AutoSize
Write-Host "`n--- Flags potentiels ---"
foreach($r in $results) {
    $p = $r.ParentResolved
    if ($p -and ($p -match '^[A-Za-z]:\\')) {
        Write-Host "FLAG: $p"
    } elseif ($p -and ($p -match '\\')) {
        Write-Host "POTENTIAL FLAG (sans lettre lecteur) : $p"
    } else {
        Write-Host "Parent non exploitable directement : $p"
    }
}
}

```

Oui j'aurai pu faire ça sous windows en GUI dans l'EventViewer avec une commande xml bien plus simple mais c'est ce qui arrive quand on se lance dans un truc qu'on ne maîtrise pas du tout.

Conclusion

Ce CTF m'a servi de niveau de référence pour mon apprentissage. J'ai su me débrouiller pour trouver un flag (après 4h) mais je n'avais ni les compétences, ni les connaissances, ni les outils.

Depuis que j'ai fais ce ctf (j'écris ces lignes le 20/10/2025) j'ai gagné en compétences sur la blue team et je pense que je serai beaucoup moins perdu sur un ctf easy. A voir si l'occasion se présente d'en faire un autre pour tester mon évolution.